ALIEN BUU WEB SERVER

BY ALIEN



สถาปัตยกรรมระบบโดยรวม (System Architecture)

แผนภาพ 4 เลเยอร์หลัก:

Layer 1 - (DNS & Network):
จัดการโดเมนผ่าน **DuckDNS** (alienbuu.duckdns.org)
ชี้มายัง IP เครื่องเซิร์ฟเวอร์

↓

Layer 2 - (Host Edge / Reverse Proxy): **Apache 2.4 & WAF**
(บน Host OS) รับทราฟฟิกภายนอก พอร์ต 80/443, จัดการ SSL/TLS
และคัดกรองคำขอก่อนส่งต่อ (ProxyPass) เข้าสู่ Docker

↓

Layer 3 - (**Docker Container** - Web App): **WordPress**
7.1.4 (PHP 8.5.12, ธีม inf-next) รันแยกสภาพแวดล้อมภายใน
Container (รับทราฟฟิกผ่านพอร์ตภายใน 127.0.0.1:8080)

↓

Layer 4 - (**Docker Container** - Database): **MariaDB** 10.11
รันภายใน Container สื่อสารผ่าน Docker Bridge Network
(Isolated Network ไม่เปิดพอร์ตออกสู่ภายนอก)

ข้อมูลจำเพาะของเครื่องแม่ข่าย (Server Specs):

- ระบบปฏิบัติการ: Ubuntu 24.04 LTS (Kernel 7.0.0-1017-azure)
- ทรัพยากร: RAM 4 GB, พื้นที่ Swap สำรอง 2 GB
- ระบบจัดการคอนเทนเนอร์: Docker & Docker Compose



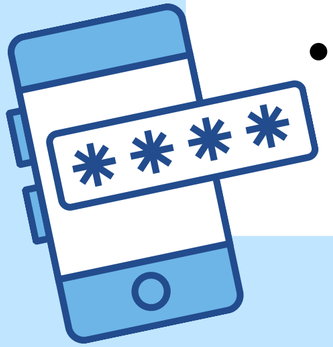
การตั้งค่าและการควบคุมการเข้าถึง VPS (VPS Hardening & Access Control)



สิ่งที่ใช้: SSH Keygen, Linux User Management, UFW (Uncomplicated Firewall)

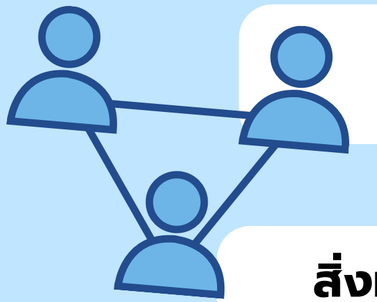
สิ่งที่ทำและเปลี่ยนแปลง:

- บังคับยืนยันตัวตนด้วย SSH Key เท่านั้น และยกเลิกการล็อกอินด้วยรหัสผ่านผ่านเครือข่าย
- ปิดการเข้าถึงสิทธิ์ Root จากระยะไกลโดยตรง (PermitRootLogin no) เพื่อบังคับให้เข้าผ่านบัญชีผู้ใช้ปกติก่อน
- หมุนเวียนรหัสผ่านบัญชีที่มีสิทธิ์ sudo ใหม่ และลบบัญชีผู้ใช้ตกค้างที่ไม่ได้ใช้งานจริง
- เปิดใช้งาน UFW Firewall คัดกรองพอร์ตขาเข้า อนุญาตเฉพาะพอร์ตที่จำเป็น (HTTP, HTTPS, SSH พร้อมตั้ง Rate Limit)





การจัดการ Container และการเชื่อมโยงระบบ (Docker, Reverse Proxy & Domain)



สิ่งที่ใช้: Docker, Docker Compose, Reverse Proxy, DuckDNS Dynamic DNS

สิ่งที่ทำและเปลี่ยนแปลง:

- จัดกลุ่มบริการด้วย Docker เพื่อแยกสภาพแวดล้อมการทำงานของระบบเว็บออกจากระบบปฏิบัติการหลัก
- ติดตั้ง Reverse Proxy ทำหน้าที่เป็นกันชนหน้าบ้าน จัดการเส้นทางคำขอ และติดตั้งใบรับรอง SSL/TLS เรียบร้อยแล้ว รองรับ HTTPS สมบูรณ์ (ได้เกรด A+ จาก testssl.sh)
- เชื่อมโยงระบบเข้ากับชื่อโดเมน alienbuu.duckdns.org แทนการเข้าถึงผ่านเลข IP Address ตรง เพื่อรองรับการทำ SSL Certificate
- หมายเหตุความสอดคล้อง: กระบวนการตรวจสอบความปลอดภัยจะทำการประเมินซ้ำตามรอบการทำงานของ Container และพอร์ตใหม่ทันทีหลังติดตั้งเสร็จสมบูรณ์





สแต็กเว็บแอปพลิเคชันและการควบคุมเวอร์ชัน (Web Stack, Plugins & Git)



หน้าบ้าน (Front-end)

พัฒนาธีมเฉพาะกิจ inf-next และหน้าแสดงผล
ข้อมูลหลักสูตรแบบ Interactive

หลังบ้าน (Back-end CMS)

ติดตั้ง WordPress 7.1.4
สำหรับบริหารจัดการเนื้อหา

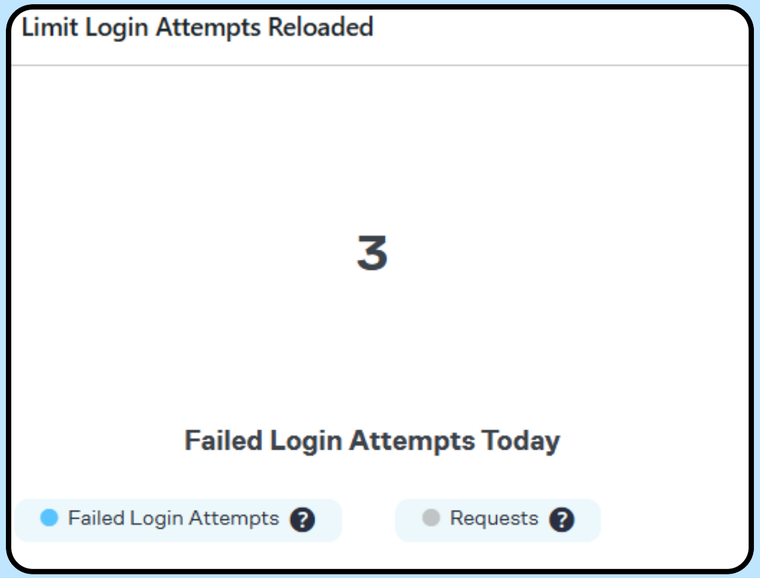
ปลั๊กอินความปลอดภัยที่ติดตั้ง

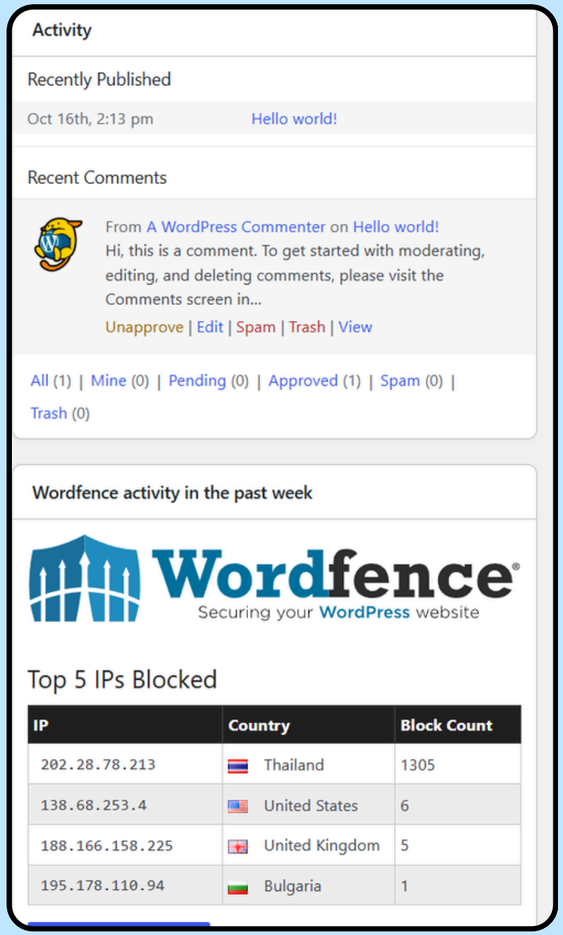
- Wordfence WAF: ตรวจจับและสกัดกั้นทราฟฟิกต้องสงสัยในระดับแอปพลิเคชัน
- Limit Login Attempts Reloaded: ป้องกันการพยายามสุ่มรหัสผ่าน
- Two Factor การยืนยันตัวสองชั้น
- WP Activity Log ตรวจสอบ log การ login หรือ request

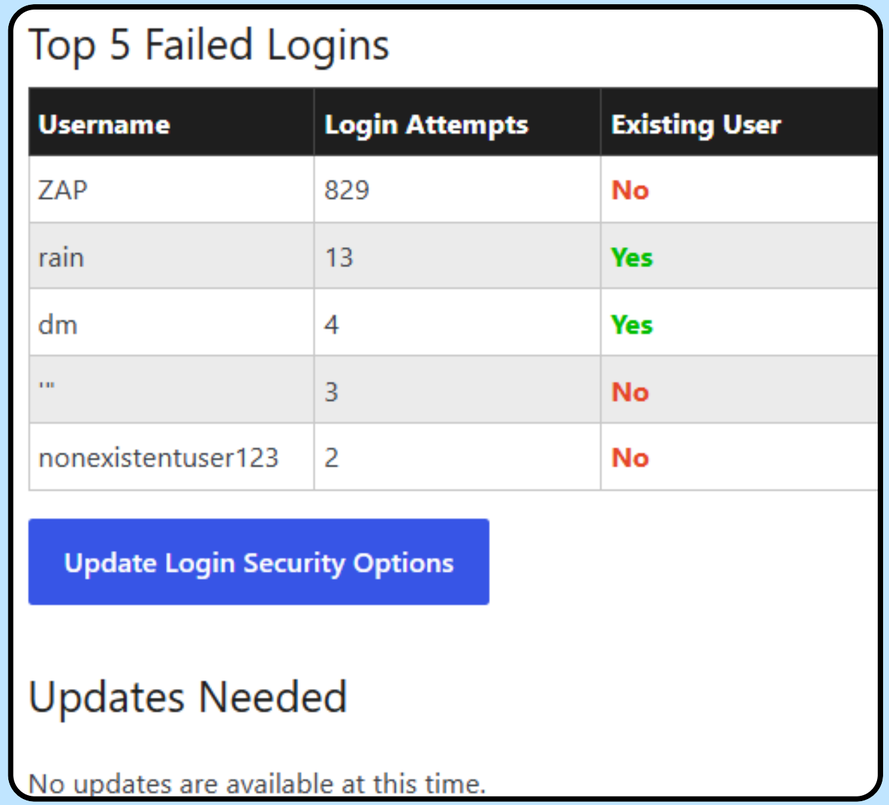
กระบวนการย้ายระบบและจัดการโค้ด

- ใช้ All-in-One WP Migration ในการโอนย้ายฐานข้อมูล และเนื้อหาจากเครื่อง Local ขึ้นสู่เซิร์ฟเวอร์ (ใช้เฉพาะช่วงการย้ายระบบ และมีมาตรการปิดกั้นเส้นทางเข้าถึง/ถอนการติดตั้งหลังเสร็จสิ้นเพื่อความปลอดภัย)
- นำระบบ Git เข้ามาควบคุมเวอร์ชันของซอร์สโค้ดธีมและคอนฟิก เพื่อให้ตรวจสอบย้อนหลังได้ทุกการเปลี่ยนแปลง

สแต็กเว็บแอปพลิเคชันและการควบคุมเวอร์ชัน (Web Stack, Plugins & Git)







กรอบการทดสอบและกระบวนการตรวจประเมิน (Security Assessment Framework)

ขอบเขตการตรวจ 3 มิติ

- ภายนอกระบบ (Black-box): พอร์ตเครือข่าย, การเปิดเผยข้อมูลเวอร์ชัน, พฤติกรรม Endpoint
- ภายในระบบ (White-box): การตั้งค่าสิทธิ์ไฟล์, นโยบายบัญชี, การปรับแต่ง Web/DB, สถิติระบบปฏิบัติการ
- ซอร์สโค้ด (SAST & Secret): โครงสร้างโค้ดธีม, mu-plugin, ข้อมูลลับและคีย์ที่อาจตกค้าง

คลังเครื่องมือที่เลือกใช้

Reconnaissance & Network Audit

- dig / nslookup: ตรวจสอบ DNS Resolution และการชี้เป้าหมาย IP ของ DuckDNS
- Nmap: ตรวจสอบพอร์ตเครือข่ายภายนอก (80, 443, 22) และยืนยันการปิดกั้นพอร์ตภายใน
- UFW: ไฟร์วอลล์ระดับโฮสต์ ควบคุมกฎการเข้าถึงพอร์ตเฉพาะที่อนุญาต

SAST & Secret Scanning

- TruffleHog: ตรวจจับคีย์ความลับ รหัสผ่าน และ Token ในไฟล์ซอร์สโค้ด
- Gitleaks: ตรวจสอบประวัติ Git เพื่อค้นหาข้อมูลลับที่อาจฝังใน Commit
- Semgrep Pro: ตรวจสอบช่องโหว่ในโค้ดตามมาตรฐาน OWASP Top 10 (293 กฎ)
- XiaomiMiMo-V2.6-Pro (Aider): วิเคราะห์ตรรกะโค้ดและการไหลของข้อมูล (Data-Flow Analysis)
- PHP_CodeSniffer + WPCS: ตรวจสอบมาตรฐานความปลอดภัยของโค้ดเฉพาะระบบ WordPress

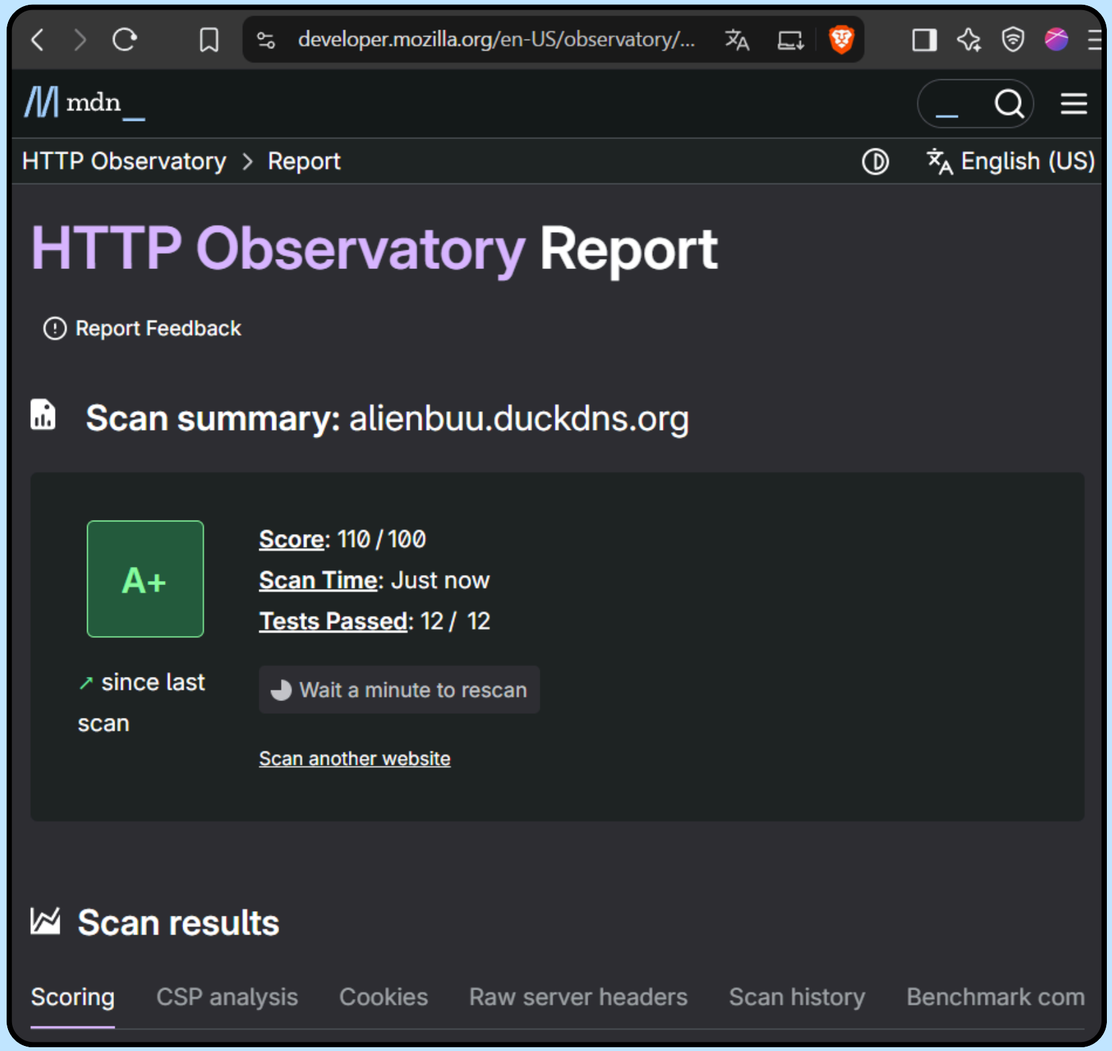
Web DAST & HTTP Transport Security

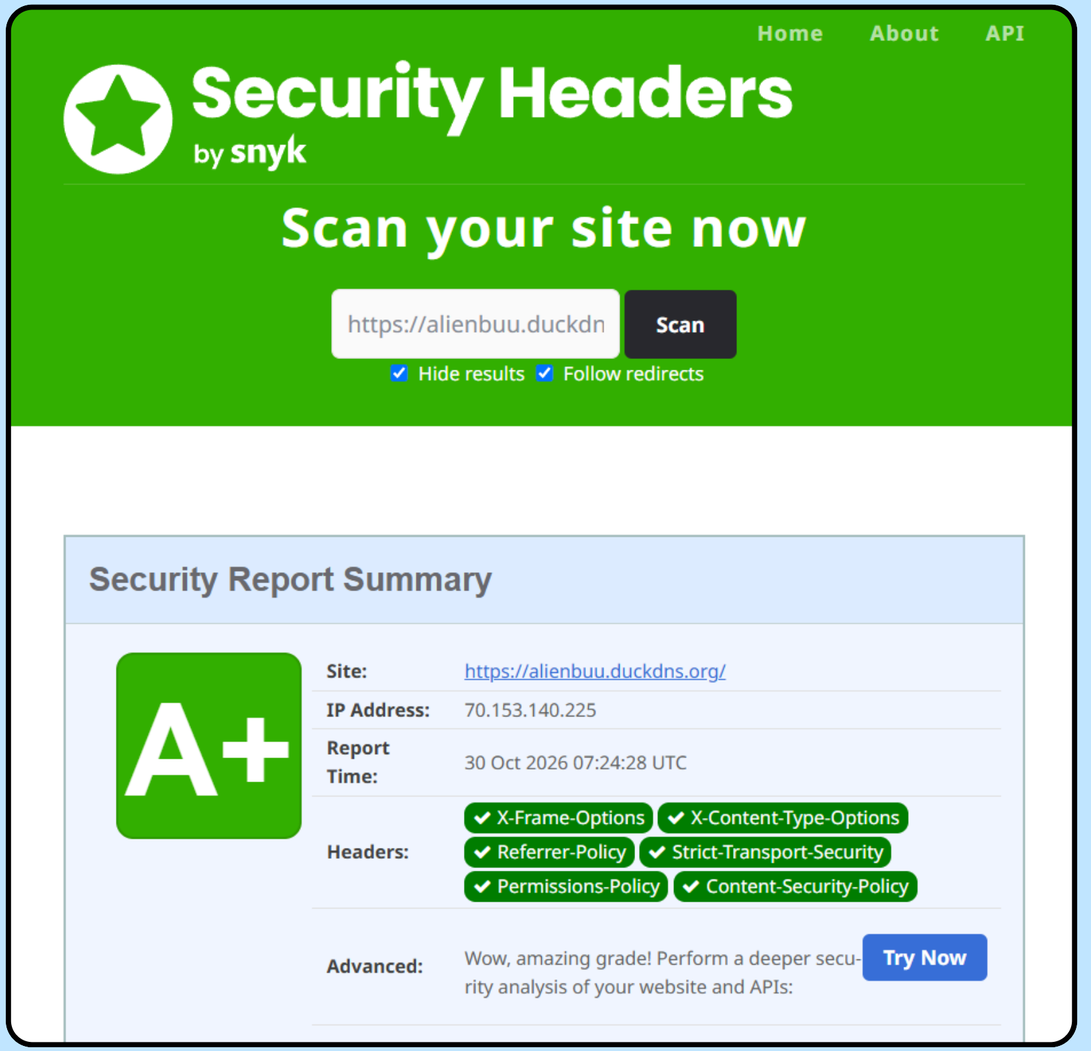
-cURL: ทดสอบ HTTP Response, Headers, การบล็อก Naked IP, XML-RPC และ WAF Rules
- OWASP ZAP: สแกนช่องโหว่เว็บแอปพลิเคชันอัตโนมัติ (DAST) และวิเคราะห์คัดกรอง False Positives
- testssl.sh: ตรวจสอบความปลอดภัยระดับ TLS/SSL Cipher Suites และช่องโหว่โปรโตคอล
- Mozilla HTTP Observatory: ประเมินคะแนนความมั่นคงปลอดภัยของ HTTP Headers (110/100 เกรด A+)
- Snyk Security Headers: ตรวจสอบการบังคับใช้นโยบาย Security Headers (เกรด A+)
- WPScan & ffuf: ตรวจสอบพื้นผิวช่องโหว่ WordPress และจำลองการสุ่มหาไฟล์ (ใช้เฉพาะช่วงต้น)

Host, Container & CMS Auditing

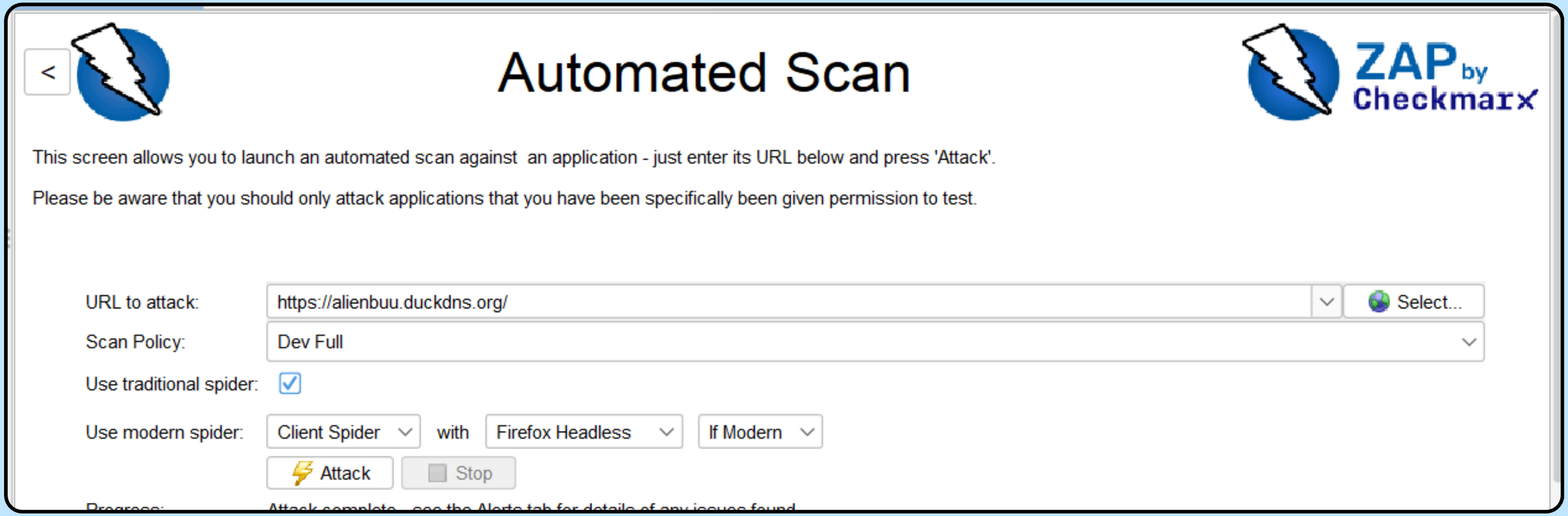
- Lynis: ตรวจสอบการปรับแต่งความปลอดภัยระดับ OS ตามแนวทาง CIS Benchmark (72/100)
- Trivy: สแกนช่องโหว่ CVE ของแพ็กเกจระบบปฏิบัติการและอิมเมจ Docker
- Ubuntu Pro (pro fix): ตรวจสอบสถานะการแพตช์ช่องโหว่เคอร์เนล Linux
- Docker CLI (inspect): ตรวจสอบความปลอดภัยคอนฟิก Binds, Network และ Environment
- WP-CLI: ตรวจสอบ Checksum ไฟล์ระบบ ความสมบูรณ์ของฐานข้อมูล และสถานะปลั๊กอิน
- Fail2ban: ระบบตรวจจับและตัดการเชื่อมต่ออัตโนมัติสำหรับ SSH และ wp-login.php

ผลการตรวจประเมิน Security Headers (Mozilla Observatory & Snyk)





การทดสอบช่องโหว่อัตโนมัติด้วย OWASP ZAP



การทดสอบภาระงานและเหตุการณ์ระบบขัดข้อง (Load Testing & DoS Mitigation)

สิ่งที่เกิดขึ้น: ระหว่างการทดสอบสแกนหาพาธและโครงสร้างระบบ บริการฐานข้อมูล MariaDB หยุดทำงานต่อเนื่องเป็นเวลานาน

วิธีตรวจพบและเครื่องมือ: ตรวจสอบเหตุการณ์จาก System Log (syslog / dmesg / kern.log) พบคำสั่งจากระบบปฏิบัติการสั่ง OOM Killer เข้าตัดโพรเซส MariaDB ทิ้ง

สาเหตุราก (Root Cause): ความไม่สมดุลของทรัพยากร เครื่องเดิมมี RAM เพียง 841 MiB และไม่มีพื้นที่ Swap ขณะที่ Web Server ตั้งค่ารับงานพร้อมกัน (Workers) ไว้สูงเกินพิกัด



การแก้ไขร่วมกัน: อัปเกรด RAM เป็น 4 GB และสร้างพื้นที่ Swap สำรองขนาด 2 GB ปรับลดเพดานการทำงานของ Web Server Worker ลงมาเหลือ 10 กระบวนการ เพื่อจำกัดการใช้หน่วยความจำไม่ให้เกินขีดจำกัด

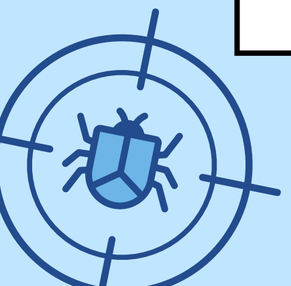
ผลลัพธ์: ระบบมีความทนทานสูงขึ้น ไม่เกิดปัญหาหน่วยความจำเต็มเมื่อถูกทดสอบซ้ำ



การตรวจพบและแก้ไขข้อบกพร่องด้านการตั้งค่าระบบ (Configuration & Infrastructure Remediation)



ปัญหาที่พบ	วิธีตรวจพบ	การแก้ไข
สิทธิ์ไฟล์คอนฟิกหลัก (wp-config.php) กว้างเกินไป	ตรวจด้วย Lynis พบสิทธิ์ 666 (แก้ไขได้ทุกคน)	ปรับเป็น 640 root:www-data และแยก Environment ด้วย Docker
การพยายามสุ่มรหัสผ่าน (Brute-Force Attacks)	ตรวจ Web Log พบคำขอยิงล็อกอิน >300 ครั้ง/ชม.	ป้องกันแบบ Multi-layer: Fail2ban (Jail wp-login), mod_evasive และ Wordfence
การดึงรายชื่อผู้ใช้ระบบ (User Enumeration)	ทดสอบ REST API ผ่าน cURL แล้วข้อมูลรั่วไหล	ติดตั้ง mu-plugin block-user-enum.php บล็อกเส้นทาง REST API (ตอบ 404)
ความเสี่ยงไฟล์สำรองข้อมูลเว็บไซต์ (.wpress)	ตรวจพบโฟลเดอร์สำรองข้อมูลของปลั๊กอินในพื้นที่เว็บ	ใช้ LocationMatch บน Apache Host สกัดกั้นด้วย 403 Forbidden และเตรียมถอนปลั๊กอิน



การวิเคราะห์ความปลอดภัยของซอร์สโค้ดและข้อมูลลับ (SAST & Secret Scanning)

วิธีที่ใช้วิเคราะห์	เครื่องมือที่ใช้	ผลการตรวจ
การตรวจหาข้อมูลความลับรั่วไหล (Secret Scanning)	TruffleHog และ Gitleaks	ไม่พบความลับรั่วไหล (0 Leaks): ไม่พบคีย์ส่วนตัว, รหัสผ่าน หรือ Token ฝังในซอร์สโค้ด
การวิเคราะห์ช่องโหว่ในโค้ด (SAST)	Semgrep Pro (293 กฎ ครอบคลุม OWASP Top 10)	0 Findings: ไม่พบช่องโหว่ร้ายแรง (SQLi, XSS, RCE) ในซอร์สโค้ดธีม inf-next
การตรวจมาตรฐานความปลอดภัยโค้ด	PHP_CodeSniffer + WPCS	พบข้อปรับปรุงระดับต่ำ: ต้องเพิ่ม Sanitization/Escaping ข้อมูลก่อนแสดงผล
การวิเคราะห์ตรรกะโค้ดและเส้นทางข้อมูล (Logic & Data-Flow SAST)	XiaomiMiMo-V2.6-Pro (Aider)	**พบข้อสังเกตระดับ Low เชิงตรรกะ:** - เงื่อนไขตรวจสิทธิ์ REST User Enum ใน mu-plugin ไม่รัดกุม - การใช้ include ดึงไฟล์ static HTML แทนการใช้ readfile() *(ทั้งสองจุดอยู่ในแผนการปรับปรุงโค้ดระยะถัดไป)*

การตรวจประเมินระบบปฏิบัติการและแพ็กเกจ (OS Benchmark & Vulnerability Verification)

วิธีที่ใช้วิเคราะห์	เครื่องมือที่ใช้	ผลการตรวจ
การตรวจสอบช่องโหว่แพ็กเกจระบบปฏิบัติการ	Trivy Scanner	0 Vulnerabilities: ตรวจสอบ 938 แพ็กเกจของ Ubuntu 24.04 ไม่พบช่องโหว่ตกค้าง
การอัปเดตและแพตช์เคอร์เนล	Ubuntu Pro (pro fix)	Resolved: อัปเกรดเป็น Linux Kernel 7.0.0-1017-azure ปิดช่องโหว่ CVE-2026-53361 สมบูรณ์
การประเมินความมั่นคงปลอดภัยระบบ (CIS Benchmark)	Lynis System Audit	Hardening Index 72/100: ดัชนีความปลอดภัยเพิ่มขึ้นจาก 63 สู่ 72 คะแนน
WordPress มีการทำ back up ทุกๆ 2.00 AM โดยจะทำการเข้ารหัสลง Google Drive โดยส่งเมลแจ้งเตือน		

การตรวจประเมินเว็บแอปพลิเคชันและความปลอดภัย HTTP (Web DAST & Security Headers)

วิธีที่ใช้วิเคราะห์	เครื่องมือที่ใช้	ผลการตรวจ
การตรวจสอบ Security Headers และการสแกนช่องโหว่ของเว็บแอปพลิเคชัน	Security Headers by Snyk, HTTP Observatory และ OWASP ZAP	• Security Headers & Mozilla Observatory: ◦ ได้เกรด A+ (110/100) ผ่านการทดสอบครบ 12/12 รายการ ◦ ติดตั้ง Header ครบถ้วน: HSTS (max-age=31536000), CSP, X-Frame-Options, X-Content-Type-Options • OWASP ZAP (Automated DAST Scan): ◦ ผลแจ้งเตือนระดับ High/Medium ทั้งหมดจัดเป็น ผลบวกลวง (False Positive) ◦ SQLi บน style.css?ver=...: เป็นเพียง Static Asset Cache-busting ไม่ได้เชื่อมฐานข้อมูล ◦ Unlock Form Alert: เกิดจากกลไกตัดการเชื่อมต่อ (HTTP 503 Lockout) ของ Wordfence WAF

ผลการตรวจประเมินความมั่นคงปลอดภัยระบบปฏิบัติการ (OS Security Audit - Lyni

วิธีที่ใช้วิเคราะห์	เครื่องมือที่ใช้	ผลการตรวจ
การตรวจประเมินความมั่นคงปลอดภัยและการตั้งค่าระบบปฏิบัติการ (OS Security Audit & System Hardening)	Lynis 3.0.9 — System Security Auditing Tool	• ภาพรวมคะแนน: ตรวจสอบ 267 รายการบน Ubuntu 24.04 (Alien-VM) ได้ Hardening Index 72/100 (Warnings: 0, Suggestions: 42) • จุดที่ผ่านการปรับแต่งแล้ว: ไฟร์วอลล์ UFW, การจำกัดสิทธิ์ SSH (ปิดรหัสผ่าน Root), และการจัดโครงสร้าง Apache Log • ข้อจำกัดและข้อแนะนำ: ◦ คำเตือน Security Repository: เป็น False Positive จากรูปแบบคอนฟิก APT แบบใหม่ (DEB822) ของ Ubuntu 24.04 ◦ ข้อเสนอแนะ 42 ข้อ: ใช้เป็นแผนปรับปรุงระยะยาว เช่น การตั้งค่า umask 027 และการกำหนดอายุรหัสผ่าน (Password Aging)

การปรับปรุงต่อเนื่องและความพร้อมในการใช้งานจริง (Ongoing Hardening & Next Steps)

- สิ่งที่ทำเสร็จแล้ว (Implemented):

Reverse Proxy + SSL เกรด A+, ปิด XML-RPC ตอบ 403, Security Headers ครบถ้วน

แผนการปรับปรุงระยะต่อไปตามรายงานการตรวจสอบ (Remaining Next Steps):

1. ลดจำนวนบัญชีในกลุ่ม sudo (จากเดิม 9 บัญชี) และเพิ่มเงื่อนไขระบุ IP ต้นทาง (from="IP") ใน SSH Authorized Keys

2. ลบบรรทัดคำสั่ง NOPASSWD ของบัญชี alien ใน /etc/sudoers.d/90-cloud-init-users โดยใช้ visudo -f

3. เพิ่มคำสั่ง define('DISALLOW_FILE_EDIT', true); ใน wp-config.php ของ Container เพื่อปิดเครื่องมือแก้ไขโค้ดผ่านหน้าเว็บ

4. ย้ายรหัสผ่านฐานข้อมูลจาก Docker Environment Variables ไปจัดเก็บใน Docker Secrets หรือไฟล์คอนฟิกที่จำกัดสิทธิ์

5. ตรวจสอบการลบไฟล์สำรองข้อมูล .wpress ออกจาก Web Root และถอนการติดตั้งปลั๊กอิน All-in-One WP Migration เมื่อสิ้นสุดการย้ายระบบ

1.6. ปรับปรุงโค้ดธีมและ mu-plugin: แก้ไขฟังก์ชันตรวจสิทธิ์เป็น current_user_can('list_users') และเปลี่ยน include เป็น readfile()

จัดทำโดย

67160053 นายณัฐรฐนนท์ ศิริกุลญาโณทัย

67160068 นายธนกร อิ่มขำ

67160101 นายภาคภูมิ อินทร

67160248 นายกันต์ธีร์ พูนสวัสดิ์พงศ์

67160254 นายจีขื่น ทาม

67160262 นายปิยวัฒน์ แซ่ซิ่น

67160267 นายเรืองเดช มาลา

67160272 วีรพงศ์ แผนจันทึก

67160425 ธนัญชัย ธนกุลบดี





Thank YOU



Scan results for https://alienbuu.duckdns.org/

These are the scan results for https://alienbuu.duckdns.org/ which scored the grade A+.

securityheaders /



Scan results - HTTP Observatory | MDN

Test your site's HTTP headers, including CSP and HSTS, to find security problems and get actionable…

MDN Web Docs

Alien Buu — วิทยาการคอมพิวเตอร์ CS – เจาะลึกหลักสูตร CS มหาวิทยาลัยบูรพา ตั้งแต่เรื่องที่เรียนถึงเส้นทางอาชีพ

Alien Buu แนะนำหลักสูตรวิทยาการคอมพิวเตอร์ CS มหาวิทยาลัยบูรพา แบบละเอียด ครบโครงสร้างหลักสูตร แผนการเรียน 4 ปี อาชีพ การรับเข้า และค่าใช้จ่าย

duckdns.org